Combined US Operations of Banco Santander, S.A.

Technology



Virus and Malware Protection Standard

TABLE OF CONTENTS

1 INTRODUCTION 3
1.1 PURPOSE OF THIS DOCUMENT 3
1.2 SCOPE AND PERIMETER 3
1.3 DOCUMENT OWNERSHIP, APPROVAL AND MAINTENANCE 3
2 GOVERNANCE AND ACCOUNTABILITY 4
2.1 STANDARD GOVERNANCE 4
3 ROLES AND RESPONSIBILITIES 5
4 STANDARD 6
4.1 STANDARD OVERVIEW 6
4.2 STANDARD REQUIREMENTS 6
4.2.1 General Requirements 6
4.2.2 Monitoring Requirements 7
4.2.3 Device Requirements 8
4.2.4 Email and Network Requirements 9
5 REPORTING STRUCTURE AND ESCALATION 10
6 EXCEPTIONS 10
7 DOCUMENT HISTORY AND VERSION CONTROL 11
7.1 OWNERSHIP AND AUTHORSHIP 11
7.2 SIGN OFF 11
7.3 SUBSIDIARY SIGN OFF 12
8 APPENDIX 13
8.1 APPENDIX A – KEY CONTACTS 13
8.2 APPENDIX B – REGULATORY OBLIGATIONS ADDRESSED BY THIS STANDARD 13
8.3 APPENDIX C – GLOSSARY 14
8.4 APPENDIX D – RELATED POLICIES AND PROCESS AND ADMINISTRATIVE DOCUMENTS 16
8.5 APPENDIX E – ANTI-VIRUS AND ANTI-MALWARE SOLUTION REQUIREMENTS BY OPERATING SYSTEM 16

1 INTRODUCTION

1.1 Purpose of this Document

The Virus and Malware Protection Standard (this "Standard") establishes the minimum mandatory requirements for preventing, detecting, and responding to malware-related threats across Combined US Operations of Banco Santander, S.A. ("CUSO") technology environments. It applies to all CUSO workforce members, and in-scope technology assets, including endpoints, servers, network components, and cloud infrastructure managed by Santander.

This Standard outlines governance and control expectations for malware protection solutions, monitoring, configuration, and response activities aligned to risk and operating environments. The objective of this Standard is to protect the confidentiality, integrity, and availability of information assets, reduce the risk of malware-driven incidents, and support regulatory compliance and operational resilience.

1.2 Scope and Perimeter

This Standard applies to CUSO, including the business units operating through Santander Holdings USA, Inc. ("SHUSA") and its subsidiaries (individually, "Subsidiary," collectively, "Subsidiaries," and together with SHUSA, "Santander US") and the Banco Santander, S.A. New York Branch ("BSNY") first line of defense functional areas within the Technology division. Additional requirements that are specific to an individual Subsidiary can be found in the exceptions section of this Standard. Operating policies and/or standards developed by the Subsidiaries must comply with the requirements set forth in this Standard.

This Standard applies to employees, contractors, vendors, volunteers, trainees, and other persons whose conduct is under the control of Santander in the performance of work for the benefit of Santander. This document applies to all equipment that is owned or leased by CUSO. For any cloud assets managed by Subsidiaries, the scope of this document applies to IaaS components.

1.3 Document Ownership, Approval and Maintenance

This Standard is categorized as a CUSO Technology (First Line of Defense) document that is updated and maintained by the CUSO Technology function. This Standard is owned by the Santander US Chief Information Security Officer ("CISO") and approved by the Santander US Head of Technology and Operations ("T&O"). This Standard is reviewed and endorsed by Subsidiary standard owners.

This Standard is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review.

2 GOVERNANCE AND ACCOUNTABILITY

2.1 Standard Governance

The Santander US CISO will:

- Own and author, review, oversee implementation of, and monitor compliance with this Standard.

The Subsidiary standard owners will:

- Review and endorse this Standard.

The CUSO Technology and Operations Executive Working Group ("T&O EWG") will:

- Review and recommend approval of this Standard to the Santander US Head of T&O.

The Santander US Head of T&O will:

- Approve this Standard.

3 ROLES AND RESPONSIBILITIES

CUSO utilizes a three lines of defense ("LoD") model for risk management, with separately defined and segregated responsibilities consistent with applicable regulations and guidance.

First Line of Defense – Risk Management

First line of defense ("1LoD") units have accountability for the primary management of the risks that emanate from their activities. 1LoD units own, identify, measure, control, monitor, and report all risks that are originated through activities such as business origination, the development, marketing or distribution of products, client maintenance, or operational or technological processes supporting customer activity.

Technology is the 1LoD unit accountable for owning, authoring, reviewing, overseeing implementation of, and monitoring compliance with this Standard. Accountabilities of individual functional areas within Technology are defined in Section 4.

Second Line of Defense – Risk Control

The **Risk** function is a second line of defense ("2LoD") unit that defines risk management frameworks and policies, independently monitors risk exposures, implements comprehensive and appropriate risk controls, and reviews and challenges 1LoD units on their activities to ensure that risk is managed in line with the agreed frameworks and Risk Appetite levels. The Risk function is organized by risk type (e.g., Enterprise Risk Management ("ERM"), Compliance, Credit, Market, Liquidity, Operational, and Model Risk) and other specialized functions (Risk Analytics) at the CUSO and Subsidiary levels. The ERM function administers Risk Governance & Reporting, Material Risk Program, Strategic Risk, Climate Risk, New Product & Business Activities, and Risk Appetite programs. The Second LoD takes primary responsibility for designing and documenting comprehensive enterprise-wide risk management framework that meets regulatory guidelines and is commensurate with the size, complexity, and risk profile of the covered subsidiaries and will be held accountable by the Chief Executive Officer ("CEO") and the Board.

Third Line of Defense – Risk Assurance

Internal Audit is independent of any other function or unit in CUSO and provides independent assurance to the Board and senior management by assessing the quality and effectiveness of the processes and systems of internal control, risk management and risk governance, compliance with applicable regulations, and the reliability and integrity of financial and operational information.

4 STANDARD

4.1 Standard Overview

This Standard defines the minimum mandatory requirements for virus and malware protection.

4.2 Standard Requirements

4.2.1 General Requirements

<table>
<tr><th>Requirement ID</th><th>Accountable Role / Function</th><th>Requirement</th></tr>
<tr><td>SUS.VMPS.4.2.1.1</td><td>Subsidiary CISO (“s-CISO”)</td><td>Virus and Malware Protection Solutions must be updated with authorized Threat Feeds or signature files from approved sources. For cloud based anti-malware solutions, solutions must be configured to be connected to their cloud console to provide telemetry, threat definition updates and extended capabilities.</td></tr>
<tr><td>SUS.VMPS.4.2.1.2</td><td>s-CISO</td><td>Malware Protection Solutions updates published by vendors must be applied within timeframes established in the following table. Automatic update procedures must be used where the technology allows.
<table>
<tr><th>Update Type</th><th>Maximum Time (Days)</th></tr>
<tr><td>Emergency Updates</td><td>Per emergency procedures</td></tr>
<tr><td>Signature/Engines updates</td><td>Three (3) days following vendor publication</td></tr>
<tr><td>Software Improvements</td><td>90 days following vendor publication</td></tr>
<tr><td>Security patches</td><td>See CUSO Vulnerability and Patch Management Standard</td></tr>
</table>
For cloud-based malware protections upgrades will be reviewed for updates on a quarterly basis and deployed in accordance with standard change management process.</td></tr>
</table>

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.1.3	s-CISO	CUSO must deploy defense-in-depth solutions to protect the organization against malware by: • Enforcement of deny lists on mobile devices, workstations and laptops. • Employment of permit lists as an alternative to deny lists, using a risk-based approach. • Usage of application sandboxing capabilities of malware protection solutions when available.
SUS.VMPS.4.2.1.4	s-CISO	Deny lists and permit lists must be maintained up-to-date and reviewed annually.
SUS.VMPS.4.2.1.5	s-CISO	Virus and Malware Protection Solutions must include machine learning-based detection and prevention capabilities configured to the maximum effective protection level as defined by the approved solution vendor. Configuration baselines and protection levels must be documented and reviewed at least annually to ensure continued effectiveness and alignment with the threat landscape.
SUS.VMPS.4.2.1.6	s-CISO	Custom detection rules (e.g., Indicators of Attack rules) within Virus and Malware Protection Solutions must require s-CISO approval and a documented risk impact assessment prior to implementation. Custom detection rules must be reviewed at least quarterly to assess continued necessity, effectiveness, and alignment with current threat intelligence.
SUS.VMPS.4.2.1.7	s-CISO	Antimalware exclusions must be configured as narrowly and specifically as possible to minimize security risk. Broad exclusions, including full directory, generic wildcard and script execution exclusions, must be classified as high-risk and must require documented justification and s-CISO or delegate approval. All antimalware exclusions must be reviewed at least annually for continued necessity.

4.2.2 Monitoring Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.2.1	s-CISO	Anti-virus and Anti-Malware events and alerts must be centrally monitored.

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.2.2	s-CISO	The availability of network perimeter Virus and Malware Protection Solutions must be continuously monitored.
SUS.VMPS.4.2.2.3	s-CISO	The availability of endpoint Virus and Malware Protection Solutions must be continuously monitored.
SUS.VMPS.4.2.2.4	s-CISO	False Positive and False Negative Detections must be monitored and minimized to improve accuracy of detection.

4.2.3 Device Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.3.1	s-CISO	A list of Applicable Corporate Devices must be maintained, reviewed and approved by the s-CISO.
SUS.VMPS.4.2.3.2	s-CISO	All applicable corporate devices are required to employ an Endpoint Detection and Response (“EDR”) system that continuously monitors usage of devices to detect and respond to cyber threats including but not limited to ransomware and malware. Note: Refer to Appendix E for mandated anti-virus and anti-malware solutions by operating system.
SUS.VMPS.4.2.3.3	s-CISO	Virus and Malware Protection Solutions with Advanced Capabilities (e.g., End Point Detection and Response Solutions) must continuously run on all workstations, laptops, and servers. Note: Refer to Appendix E for mandated anti-virus and anti-malware solutions by operating system.
SUS.VMPS.4.2.3.4	s-CISO	Security configurations for Virus and Malware Protection Solutions must be applied according to the *CUSO Secure Build and Configuration Management Standard*.
SUS.VMPS.4.2.3.5	s-CISO	Security Configurations of Virus and Malware Protection Solutions must be protected from any modification by non-authorized users. Antimalware agents must be protected against unauthorized uninstallation and service shutdown. Any unauthorized attempt to disable, stop, or uninstall the agent must be logged and reported.

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.3.6	s-CISO	Non-Corporate Devices without an approved and updated Malware Protection Solution must be Quarantined. Quarantined devices must contain the capacity to be sanitized.
SUS.VMPS.4.2.3.7	s-CISO	Virus and Malware Protection Solutions must provide remote response capabilities enabling authorized security personnel to execute commands, collect forensic artifacts, and retrieve files from endpoints for detailed analysis in support of incident response activities.

4.2.4 Email and Network Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.VMPS.4.2.4.1	s-CISO	E-mail protection mechanisms must be used to filter for common cyber threats.
SUS.VMPS.4.2.4.2	s-CISO	Security Filtering Techniques must be applied to prevent malicious content in incoming email. Email gateways must contain: • Anti-spoofing mechanisms • Sender reputation filtering • Anti-spam filtering mechanisms • Anti-phishing filtering mechanism
SUS.VMPS.4.2.4.3	s-CISO	The Sender Policy Framework (“SPF”) must be implemented in the receiver-side of e-mail verification.
SUS.VMPS.4.2.4.4	s-CISO	All incoming email traffic from third party connections must be analyzed for malware.

5 REPORTING STRUCTURE AND ESCALATION

As part of an overarching risk assessment and reporting program, CUSO must conduct regular self-assessments to measure design adequacy and operating effectiveness of controls specified in this Standard. The results must be incorporated into risk reporting provided to the CUSO 2LoD functions, and to the Board, if applicable, in accordance with 2LoD function governance requirements.

6 EXCEPTIONS

Standard exceptions are expected to be infrequent but may be granted to address specific business needs. Subsidiary-specific exceptions require review and approval from both the s-CISO and the Santander US CISO. All approved Subsidiary-specific exemptions are listed in the table below.

Any additional material exceptions not explicitly defined in this section must include documented rationale, an assessment of associated risks (where applicable), and any other relevant details. These exceptions must be reviewed and approved during the Security Exceptions Function ("SEF") meeting.

Subsidiary:	Exceptions:
SBNA:	• No exceptions
BSNY:	• Appendix E - BSNY does not utilize the MacOS and AIX operating systems.
SanCap:	• Appendix E - SanCap does not utilize the MacOS and AIX operating systems.
SC:	• Appendix E - SC does not utilize the AIX operating system.
BSI:	• Appendix E - BSI does not utilize the MacOS and AIX operating systems.

7 DOCUMENT HISTORY AND VERSION CONTROL

7.1 Ownership and Authorship

Version	Author	Owner	Change
1.0	Santander US Information Security	Santander US CISO	Initial Version
1.1	Santander US Information Security	Santander US CISO	Annual Review
2.0	Santander US Information Security	Santander US CISO	Annual Review
3.0	Santander US Information Security	Santander US CISO	Annual Review
4.0	Santander US Information Security	Santander US CISO	December 2022 Off Cycle Material Update
5.0	Santander US Information Security	Santander US CISO	2022 Annual Review
5.1	Santander US Information Security	Santander US CISO	2023 Annual Review
5.2	Santander US Information Security	Santander US CISO	2024 Annual Review
5.3	Santander US Information Security	Santander US CISO	2025 Off Cyle Updates to align with group's cyber security policies
6.0	CUSO Information Security	Santander US CISO	2025 Annual Review

7.2 Sign Off

Approver	Action	Date
Santander US Head of T&O	Approve	07/28/2026

7.3 Subsidiary Sign Off

Approving Body	Governance Committee Approval or Endorsement	Final Approval Date
Santander US CISO	Endorsement	07/22/2026
SBNA CISO	Endorsement	05/08/2026
Santander US Auto Chief Information Officer (“CIO”)	Endorsement	07/21/2026
BSI CIO	Endorsement	07/23/2026
Santander US Corporate and Investment Banking (“CIB”) CIO	Endorsement	07/28/2026

8 APPENDIX

8.1 Appendix A – Key Contacts

Title	Role	Contact Information
Santander US Head of T&O	CUSO Technology	Patryk Nowakowski (patryk.nowakowski@santander.us)
Santander US CISO	CUSO Information Security	Alberto Hernandez (Alberto.Hernandez@santander.us)
Santander US Auto CIO	CUSO Technology	Bobby Mehra (bobby.mehra@santander.us
Sr. Director, Information Security	CUSO Information Security	Rebecca Smith (rebecca.smith@santander.us)
SBNA CISO	CUSO Information Security	Andre Salgado (andre.salgado@santander.us)
Director, Information Security	CUSO Information Security	Jorge Lobo Cruz (jorge.lobo@santander.us)
BSI CIO	Banco Santander International Technology	Jose Oliveros (joliveros@bpi-gruposantander.com)
Sr. Director, Information Security	Banco Santander International Technology	Dayam Borges (dborges@bpi-gruposantander.com)
Santander US CIB CIO	CUSO Capital Markets, LLC/Banco Santander New York Technology	Xavier Jean Courtois (xavier.courtois@santander.us)
CIB CISO	CUSO Capital Markets, LLC/Banco Santander New York Technology	Frank Hsieh (frank.hsieh@santander.us)

8.2 Appendix B – Regulatory Obligations Addressed by this Standard

The following are the primary regulations addressed by CUSO Technology Standards:

- GLBA 501(b) - Interagency Guidelines Establishing Standards for Safeguarding Customer Information
- GLBA 501(b) - Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice

In addition, CUSO considered the following supervisory sources in developing Standards and in its ongoing assessment and oversight of risk:

- Federal Financial institutions Examination Council (“FFIEC”) IT Handbook, including:
  - Information Security Booklet
  - Development and Acquisition Booklet
  - Architecture, Infrastructure, and Operations Booklet
  - Management Booklet
  - Outsourcing Technology Booklet
  - Supervision of Technology Service Providers Booklet
  - Business Continuity Management Booklet
- Office of the Comptroller of the Currency (“OCC”) Model Risk Management booklet of the Comptroller's Handbook
- US Securities and Exchange Commission 2017-02 Guidance Update (Robo Advisers)
- National Institute of Standards and Technology (“NIST”) Artificial Intelligence Risk Management Framework (AI RMF 1.0)
- International Standards Organization (“ISO”) ISO/IEC 38507:2022 Information Technology — Governance of IT — Governance implications of the use of Artificial Intelligence by organizations
- The National Cyber Security Centre (“NCSC”) Guidelines
- Personal Data Protection Commission Singapore (“PDPC”) Model
- Monetary Authority of Singapore

8.3 Appendix C – Glossary

Term	Definition
Advanced Capabilities	Refers to detect and response Malware Protection Solution capabilities. Detection is done through continuous monitoring and analyzing activities and behavior to identify and spot abnormal behaviors that are indicative of malicious activities. Detection also provides analytics information including process actions for investigation. Response capabilities refer to capacity to mitigate risk as for example being able to isolate or remove the threat.
Anti-phishing	Process to identify and block phishing content contained in e-mail.
Anti-spam	Process to prevent the proliferation of spam or to keep spam from entering mail system.
Anti-spoofing	Process to identify and drop emails that have a false source address.
Email Gateway	A gateway that is designed to connect two or more mail systems.
False Negative Detections	An instance in which a security tool intended to detect a particular threat fails to do so.

Term	Definition
False Positive Detections	An instance in which a security tool incorrectly classifies benign content as malicious.
Malicious Content	The malware itself or the attack vector to deliver the malware to the victim. For example, the exploit a website is using to drop a Trojan via a browser vulnerability in a victim's device is malicious website content.
Malware	A program that is inserted into a system, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of the victim's data, applications, or operating system or of otherwise annoying or disrupting the victim.
Malware Incident	A Malware occurrence that jeopardizes the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.
Malware Protection Solution	A program that monitors a computer or network to identify all major types of malware and prevent or contain malware incidents.
Quarantine	The process of isolating a device for future sanitization.
s-CISO	The executive accountable for managing the Information Security function at one of CUSO Subsidiaries.
Santander US CISO	The executive accountable for managing the Information Security function at CUSO.
Security Filtering Techniques	The process of monitoring communications (e.g., email and web pages), analyzing them for suspicious content, and preventing the delivery of suspicious content to users.
SPF	The SPF is an e-mail validation protocol that blocks e-mail spoofing.
Sender Reputation Filtering	Process to identify and block emails that have a bad reputation source address.

8.4 Appendix D – Related Policies and Process and Administrative Documents

Document Type	Subsidiary / Department	Owner	Title
Policy	CUSO Operational Risk Management	Santander US Chief Operational Risk Officer	CUSO Information Risk Management Enterprise Policy
Policy	CUSO Technology	Santander US CISO	CUSO Information Security Operating Policy
Standard	CUSO Technology	Santander US Head of Infrastructure	CUSO Asset Management Standard
Standard	CUSO Technology	Santander US CISO	CUSO Vulnerability and Patch Management Standard

8.5 Appendix E – Anti-virus and Anti-malware Solution Requirements by Operating System

Operating System	Standard Capabilities	Advanced Capabilities
Microsoft Windows	ü	ü
MacOS	ü	ü
Linux	ü	ü
AIX	X	X
Solaris	X	X